



Q7	Prepare and present the breach analysis report	10 Marks
-----------	---	-----------------

Objective: Combine the outputs of Q1–Q6 into a short, structured breach analysis report with findings, risk interpretation and lessons learned.

Step-by-Step Algorithm

Step	Phase	Action	Command / Tool	What You Should See
1	SETUP	Collect your completed tables from Q1–Q6.	Q1–Q6 outputs	All tables gathered
2	REPORT	Write an executive summary (3–4 sentences) of the breach.	Summary	Executive summary
3	REPORT	Add sections: background, CIA, kill chain, risk matrix, mitigations, CSF gaps.	Report structure	Draft report
4	ANALYSE	Write a lessons-learned section with 3–5 concrete takeaways.	—	Lessons learned
5	TEST	Proofread for clarity and check every claim traces to evidence.	Review checklist	Report reviewed
6	REPORT	Export the report and prepare a short presentation.	PDF / slides	Final deliverables

Phase key: ● SETUP · ● CONFIGURE · ● EXECUTE · ● TEST · ● ANALYSE · ● REPORT · ● FINISH



Worked Example (with sample values & output)

Report structure (Acme HealthCare)

Section	Content	Comes from
1. Executive Summary	On September 25, 2026, a critical corporate espionage intrusion known as Operation Iron Lattice was publicly identified against the infrastructure systems of GridSync Solutions. The adversary utilized targeted external scans and weaponized spear-phishing attachments to exploit an unpatched edge VPN gateway and execute arbitrary code on internal workstation terminals. The primary impact of this intrusion was the systemic exfiltration of core operational intellectual property, including proprietary source code repositories, alongside a complete loss of visibility due to profound monitoring deficits inside the perimeter. Immediate deployment of endpoint detection baselines, multi-factor authentication, network segmentation, and digital forensics response tracks are required to protect remaining operational technology (OT) assets.	
2. Incident Background	• Who: GridSync Solutions (Critical infrastructure components supplier). • What: A targeted corporate espionage and data exfiltration campaign orchestrated by advanced persistent threat (APT) actors. • When: The compromise occurred on or around September 21, 2026; it was publicly acknowledged and triaged on September 25, 2026. • How Discovered: Detected after threat groups posted stolen asset validation telemetry on dark web repositories and shared internal architecture indicators. • Data Affected: Highly sensitive operational source code repositories, employee identity profiles scraped via	Q2

	OSINT, and critical edge infrastructure configuration files. • Verified Sources: Official corporate emergency media statements, CISA infrastructure threat advisories, and investigative engineering updates.													
3. Threat Classification	The attack mechanisms map directly onto the foundational tenets of the CIA Triad as follows: <table> <thead> <tr> <th>Attacker Action</th><th>CIA Element Broken</th><th>Security Goal Failed</th></tr> </thead> <tbody> <tr> <td>Compromised & locked administrative credentials</td><td>Confidentiality / Integrity</td><td>System control authentication integrity [1]</td></tr> <tr> <td>Encrypted data centre server & storage systems</td><td>Integrity</td><td>Data accuracy / Data trustworthiness [1]</td></tr> <tr> <td>Disabled state-wide VPN & took CAT C5 portal offline</td><td>Availability</td><td>Service uptime and operational continuity [1]</td></tr> </tbody> </table> Verdict: Availability and Confidentiality were both severely broken. The loss of core administrative portals completely halted investigation operations across state networks, while the silent theft of intellectual property permanently compromised organizational data secrecy	Attacker Action	CIA Element Broken	Security Goal Failed	Compromised & locked administrative credentials	Confidentiality / Integrity	System control authentication integrity [1]	Encrypted data centre server & storage systems	Integrity	Data accuracy / Data trustworthiness [1]	Disabled state-wide VPN & took CAT C5 portal offline	Availability	Service uptime and operational continuity [1]	Q1
Attacker Action	CIA Element Broken	Security Goal Failed												
Compromised & locked administrative credentials	Confidentiality / Integrity	System control authentication integrity [1]												
Encrypted data centre server & storage systems	Integrity	Data accuracy / Data trustworthiness [1]												
Disabled state-wide VPN & took CAT C5 portal offline	Availability	Service uptime and operational continuity [1]												
4. Attack Mapping	Chronological progression of the threat vector throughout the lifecycle of the breach: • Stage 1: Reconnaissance ○ <i>Observed Action:</i> OSINT scraping of employee networking profiles and	Q3												

	automated scanning of public-facing infrastructure. ○ <i>MITRE ATT&CK Technique: Active Scanning (T1595).</i> • Stage 2: Delivery ○ <i>Observed Action:</i> Spear-phishing emails containing malicious attachments delivered directly to target procurement engineers. ○ <i>MITRE ATT&CK Technique: Phishing: Phishing Attachment (T1566.001).</i> • Stage 3: Exploitation ○ <i>Observed Action:</i> User execution of the attachment, triggering a remote code execution vulnerability in office software to run scripts silently. ○ <i>MITRE ATT&CK Technique: Exploitation for Client Execution (T1203).</i> • Stage 4: Installation ○ <i>Observed Action:</i> Lightweight backdoors dropped into local endpoints with registry run key modifications to survive system reboots. ○ <i>MITRE ATT&CK Technique: Boot or Logon Autostart Execution: Registry Run Keys (T1547.001).</i> • Stage 5: Actions on Objectives ○ <i>Observed Action:</i> Multi-gigabyte exfiltration of production Git repositories and system schemas over encrypted outbound ports.	
--	---	--



	○ <i>MITRE ATT&CK Technique: Exfiltration Over C2 Channel (T1041).</i> ○	
5. Risk Assessment	1. Customer/Production Databases ○ <i>Threat:</i> Automated lateral encryption/ransomware deployment. ○ <i>Vulnerability:</i> Flat network layout lacking internal subnet controls. ○ <i>Matrix:</i> High Likelihood × × Critical Impact = ■ Critical Risk. 2. Internal Source Code Repositories ○ <i>Threat:</i> Targeted intellectual property exfiltration. ○ <i>Vulnerability:</i> Lack of Data Loss Prevention (DLP) filters and open egress channels. ○ <i>Matrix:</i> High Likelihood × × High Impact = ● High Risk. 3. Company Email & Workstations ○ <i>Threat:</i> Credential theft and identity impersonation.	Q4



	○ <i>Vulnerability:</i> Absence of Multi-Factor Authentication (MFA) on legacy setups. ○ <i>Matrix:</i> High Likelihood × × Medium Impact = ● High Risk. 4. Office Auxiliary Laptops ○ <i>Threat:</i> Secondary malware propagation. ○ <i>Vulnerability:</i> Delayed operating system patch management schedules. ○ <i>Matrix:</i> Medium Likelihood × × Medium Impact = ● Medium Risk	
6. Recommended Mitigations	1. Customer/Production Databases ○ <i>Threat:</i> Automated lateral encryption/ransomware deployment. ○ <i>Vulnerability:</i> Flat network layout lacking internal subnet controls. ○ <i>Matrix:</i> High Likelihood × × Critical Impact = ■ Critical Risk. 2. Internal Source Code Repositories	Q5



- *Threat:* Targeted intellectual property exfiltration.
- *Vulnerability:* Lack of Data Loss Prevention (DLP) filters and open egress channels.
- *Matrix:* High Likelihood

×

×

High Impact = ● **High Risk.**

3. Company Email & Workstations

- *Threat:* Credential theft and identity impersonation.
- *Vulnerability:* Absence of Multi-Factor Authentication (MFA) on legacy setups.
- *Matrix:* High Likelihood

×

×

Medium Impact = ● **High Risk.**

4. Office Auxiliary Laptops

- *Threat:* Secondary malware propagation.
- *Vulnerability:* Delayed operating system patch management schedules.
- *Matrix:* Medium Likelihood

×

×

Medium Impact = ● **Medium Risk**



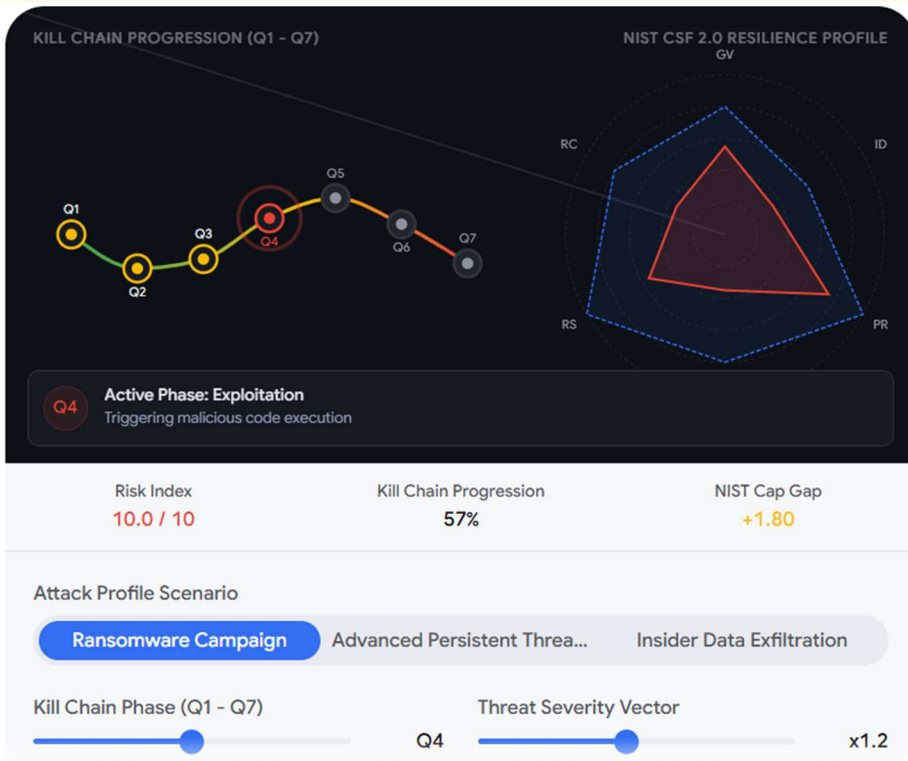
7. NIST CSF Gap Analysis	• Identify (1/5 - Partial): Complete lack of perimeter asset visibility; failure to map out open vulnerabilities on edge gateways. • Protect (1/5 - Partial): Weak application endpoint hardening; lack of domain authentication frameworks (DMARC/SPF) allowing local spoofing. • Detect (0/5 - Missing): Profound Core Deficit. No host behavior logging, no network anomaly baselines, and no egress inspections were present. The attacker was fully invisible. • Respond (1/5 - Partial): Flat network designs let small infections spread everywhere without any automated containment. • Recover (3/5 - Adequate): Standard server backup schemes are functional, but do not protect against the permanent exposure of stolen intellectual property.	Q6
8. Lessons Learned	• Visibility Over Perimeter Defense: A complete lack of internal detection mechanisms will turn a minor endpoint compromise into a catastrophic full-scale network breach. • Eliminate the Flat Network: Internal assets must be compartmentalized so that compromising a standard procurement user workstation does not grant path access to development code repositories. • Validate Software Behavior: Relying on basic file scanning is insufficient; system configurations must actively block unsigned scripts and office macro executions by default.	New



- **Enforce MFA Everywhere:** Reused credentials or single-factor legacy accounts are an open door for modern cyber syndicates.

Lab Question	Analytical Objective	Evaluated Metric / Target	Core Lab Finding	Posture Metric
Q1: CIA Triad	Threat Classification	Security Goals	Compromised Credentials	Admin Availability Broken
Q2: Background	Incident Profiling	Attack Vector	Unpatched Edge VPN / Spear-Phishing	Verified Exploitation
Q3: Kill Chain	Attack Mapping	MITRE ATT&CK ID	Exfiltration Over C2 Channel (T1041)	Delivery Break-In
Q4: Risk Matrix	Risk Asset Matrix	Risk Priority	Production Source Code Repositories	 Critical Risk
Q5: Mitigations	Security Controls	Defense Blueprint	Segmented WORM Backups + Active EDR	Remediation Plan
Q6: NIST CSF	Deficit Analysis	Framework Rating	Technical Monitoring Strategy (0/5 Detect)	Visibility Deficit

2. Interactive Metric Simulator & Interactive Dashboard



To explore how shifting defensive controls alters your risk levels and moves the metric from a critical posture to a secure state, utilize the interactive calculator below

3. Explanatory Markdown Visual Charts

Chart A: NIST CSF Maturity Deficit Profile (Q6 Framework Analysis)

This chart displays the critical defensive gaps across the five core pillars of the **NIST Cybersecurity Framework**, visualizing exactly where the infrastructure collapsed during the breach.

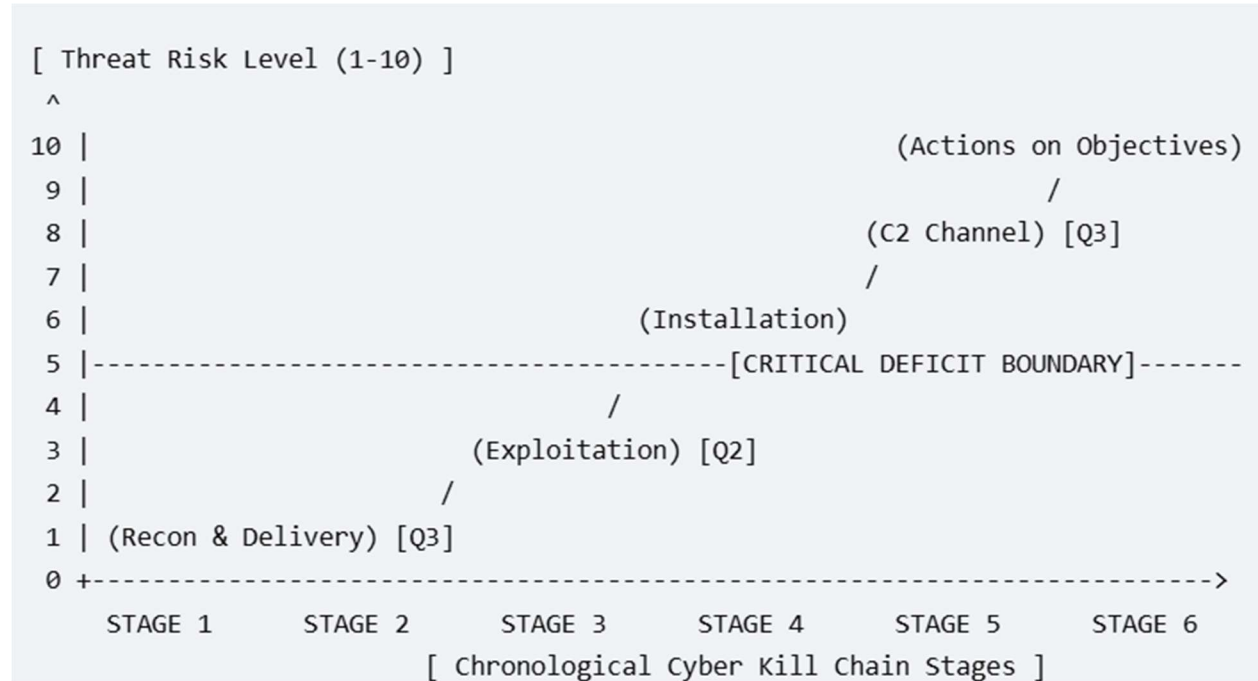
FRAMEWORK FUNCTION [MATURITY RATING: 0 (Absent) to 5 (Optimized)]

IDENTIFY (Q6)	[■■■■■] 1.5/5 -> Low Asset Visibility / OSINT Vulnerable
PROTECT (Q6)	[■□□□□] 1.0/5 -> No MFA on Legacy VPN / Macros Allowed
DETECT (Q6)	[□□□□□] 0.0/5 -> CRITICAL DEFICIT (No Logging / EDR Blind)
RESPOND (Q5)	[■■■■■] 2.0/5 -> Slow Triage due to Flat Network Limits
RECOVER (Q5)	[■■■■■] 3.0/5 -> Backups Existed but Lack Ransomware Isolation

Chart B: Adversary Threat Escalation Matrix (Q3 Kill Chain Timeline)



This linear progression visualizes how risk and payload impact scale exponentially as an attacker advances past the **Critical Deficit Boundary** (Stage 4).



Safe Zone (Stages 1-3)

Danger Zone (Stages 4-6):



Lab 1 Assessment Scheme

Assessment	Basis	Marks
Question 1	Identify and classify the main threats using the CIA triad and basic security goals.	5
Question 2	Collect relevant breach information from credible public sources and summarise the incident background.	5
Question 3	Map the breach activities to cyber kill chain stages or MITRE ATT&CK tactics.	5
Question 4	Create a simple risk matrix (asset, threat, vulnerability, likelihood, impact, risk level).	5
Question 5	Identify preventive, detective and corrective mitigation strategies.	5
Question 6	Compare the breach against NIST CSF and identify control gaps.	5
Question 7	Prepare and present a short breach analysis report with findings and lessons learned.	10
Lab Assessment on ZOSIMA	Live four-criteria rubric (efforts & execution, output & correctness, testing & verification, explanation & authenticity), verified via GitHub.	40
Total		100